

Beyond the Demo: Building Trusted AI Agents with MCP

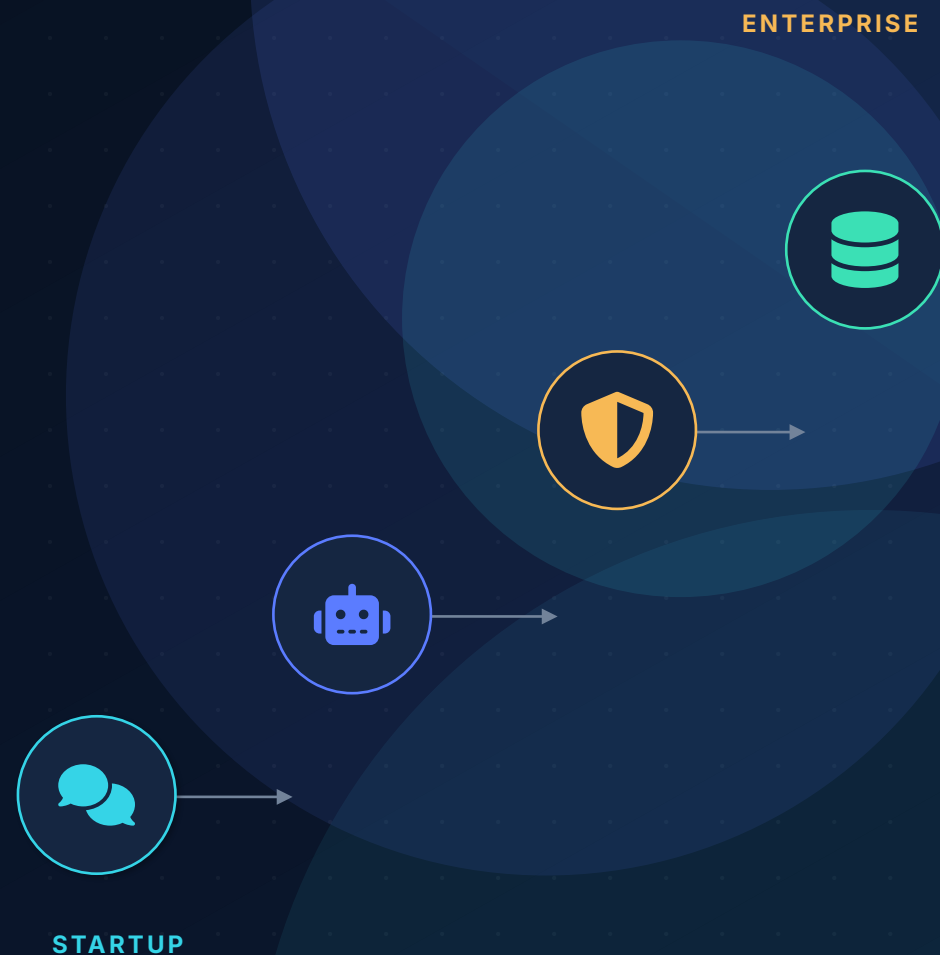
A startup story, an enterprise reality,
and lessons from real implementations.

Constantine Grigoroff

Principal Data & AI Engineer · Shell Trading & Supply

20 OCT 2026 · RAI AMSTERDAM

AI DEVELOPER · 12:05–12:35



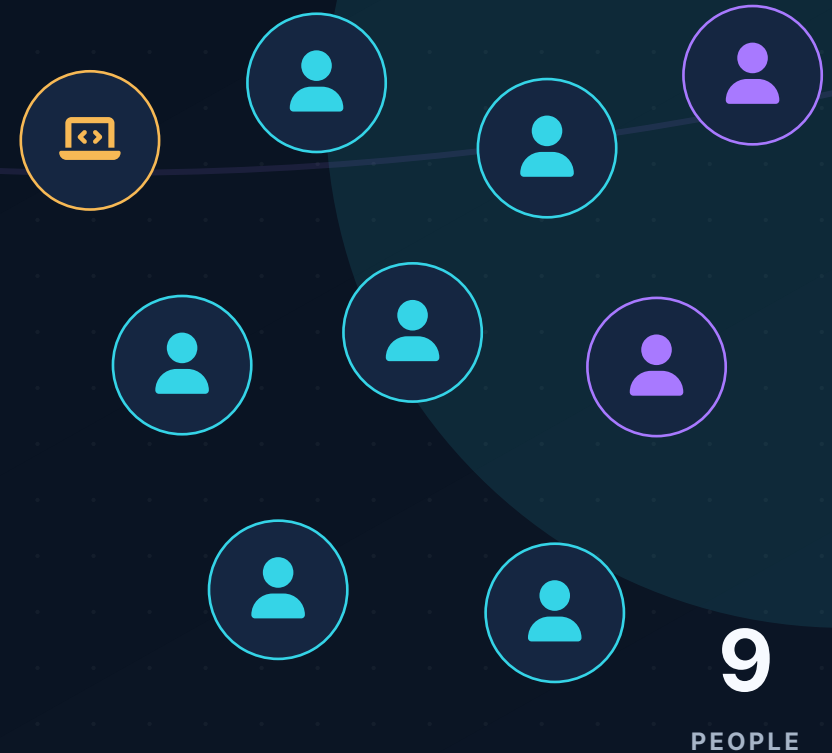
Fictional story. Real failure modes.

You've joined a nine-person startup.

Team of 9. Funding secured. Friday demo.

GOAL: CONNECT AN LLM TO REAL DATA THROUGH MCP

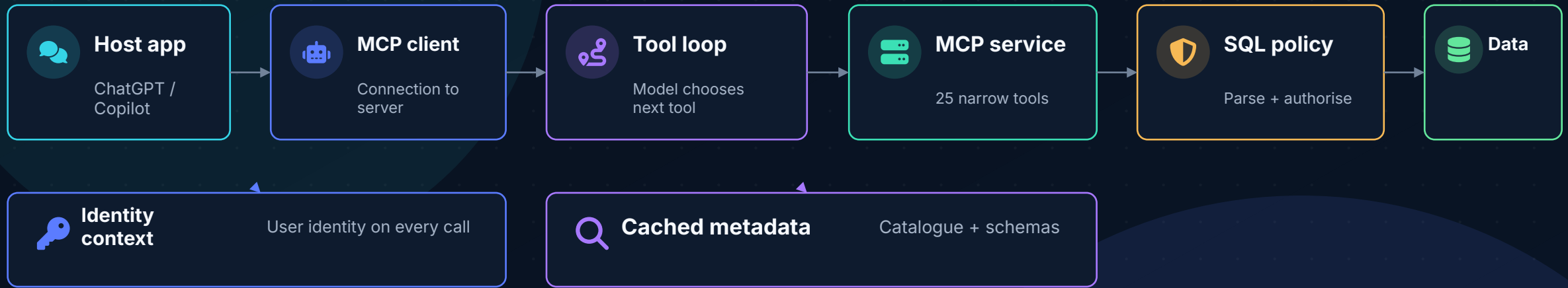
*Trusted users. One identity path. One team.
A tool catalogue small enough to understand.*



ASSUMPTION DEBT

Small solutions are safe only while
their hidden assumptions remain true.

A practical MCP implementation



THE DESIGN PRINCIPLE

A deterministic spine around a probabilistic model.

The model interprets language. Code constrains execution.

OUTPUT ADAPTERS



Table



CSV



Excel



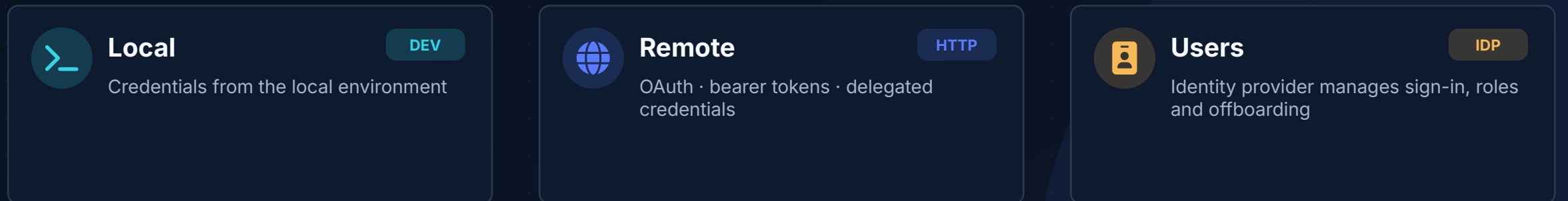
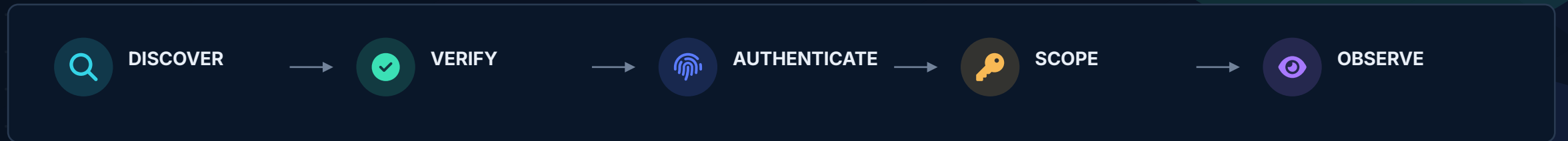
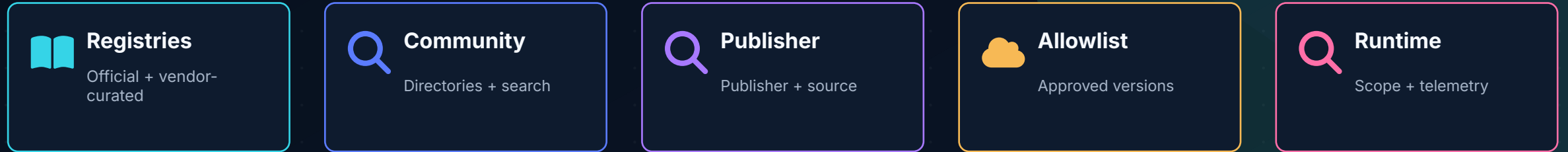
Chart



Map

STARTUP QUESTION: HOW DO WE CONTROL WHAT THE MODEL DOES?

Discovery outpaces approval



REGISTRY ≠ ENDORSEMENT

Customer acquisition: the VC arrives

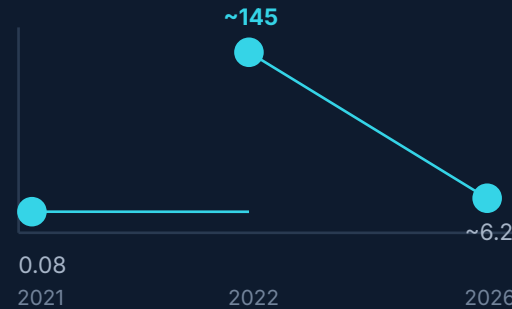
PRIORITY CUSTOMER



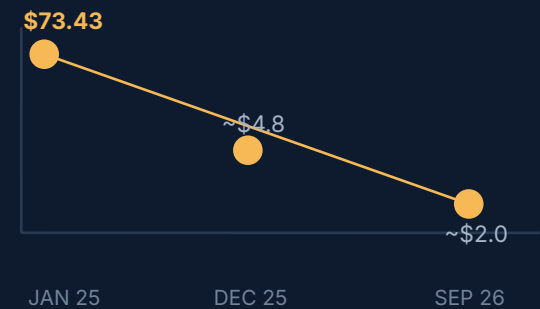
"Can your agent analyse my portfolio?"

Nothing clarifies product priorities like consequences.

BAYC FLOOR · ETH



TRUMP COIN · USD



THE REQUIREMENTS CHANGE

- 👁️ Who can see my data? How long is it kept?
- ⚡ Can the agent take a durable action?
- 🕒 Can I reproduce the answer?

CONTAINED BLAST RADIUS

Milestone illustration, not a daily price series.

Production expands the control surface



Identity & entitlements

Caller identity · dataset access



Least privilege

Read-only SQL · exact relations



Guardrails

Safe reads · reject writes · fail closed



Audit & telemetry

Request · route · outcome
Logs are part of the security boundary



Evidence & provenance

Dataset · SQL · source metadata



Tests & release gates

~470 automated tests
Unsafe requests must be rejected

STARTUP

Implement controls inside one product.



ENTERPRISE

Enforce controls consistently across every product.

TRUST = CONTROL + EVIDENCE

Security is not a workstream. It is the work.

50%

of surveyed MCP builders

cite security / access control
as their top challenge.



Authenticated ≠ authorised.
Issuer · audience · expiry · scope



"Security and access control is the top challenge for builders, cited by 50% of respondents."

Zuplo · State of MCP survey · fielded Nov–Dec 2025 · self-selected, no N published

38%

blocked by security concerns

~24%

of respondents run servers with no authentication

MEASURED, NOT SELF-REPORTED: 40.55% OF 7,973 LIVE SERVERS EXPOSE TOOLS WITH NO AUTH · arXiv:2605.22333

IDENTITY · ACTION · RESOURCE · AUTHORITY — VALIDATE THE COMPLETE CONTEXT

"This might take longer."

PROJECT CHAT

Founder

Can we add enterprise SSO?

Engineer

Sure. That should be manageable.

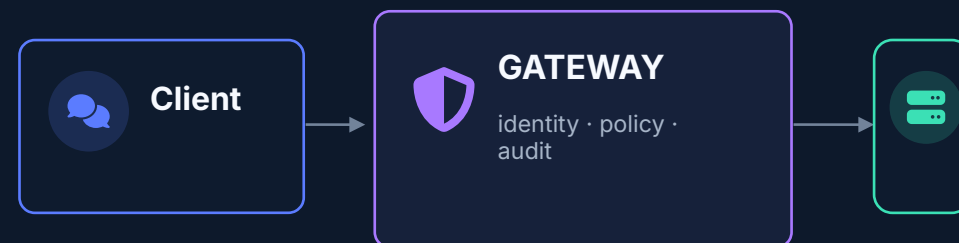
Security

Great. Also delegated identity, user + non-user personas, entitlements, token exchange, audit, tenant isolation, offboarding...

Engineer

This might take longer.

TARGET: ENTERPRISE MCP GATEWAY



Authenticate once



Delegate identity



Enforce policy



Unify telemetry

arXiv:2608.10760 · production pattern



OWASP MCP TOP 10

IMPLEMENTED: STATELESS HTTP

Stateless requests scale cleanly; session context remains optional.

Accuracy starts with routing and ends with evidence

1



Preserve the prompt

Original wording + request ID

2



Explicit route

Return one required next step

3



Trusted template

Embeddings select trusted SQL;
they do not invent it.

4



Hybrid retrieval

70% lexical · 30% vector

5



Schema + safety

Verify schema · parse · authorise

6



Execute + evidence

Read-only result + evidence

CONFIDENCE GATE



LOW

HIGH



No confident
match?
Ask or stop.

SERVER

returns next step

CLIENT

calls next tool

Confidence protects accuracy; validation and authorisation protect safety.

REPEATABILITY: REQUEST · ROUTE · QUERY · DATA · EVIDENCE

The data contract enters the routing layer



VENDOR DATA AGREEMENT

- ⊘ AI / machine-learning use
- ⊘ Copying and retention
- ⊘ Storage location
- ⊘ Licensed identity and purpose
- ⊘ Use of derived data

**The policy must shape routing
before the model sees the data.**

Separate relevance from permission.

This identity · this application · this purpose



Access denied → stop

Terminal result · the client is told to stop



Bring compute to the data

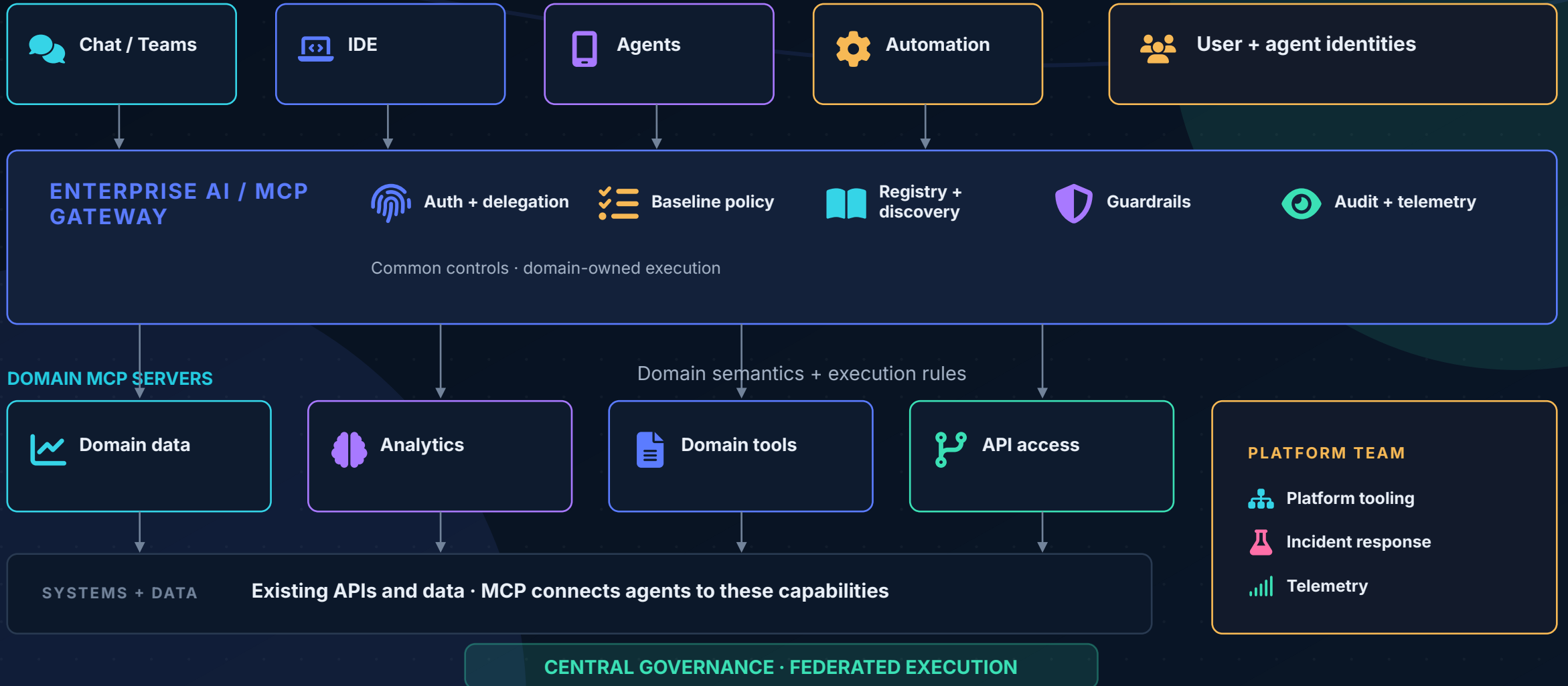
Minimise copies · process within the permitted boundary

Governed views · private inference · synthetic evaluation

CONTRACT TERMS BECOME POLICY INPUTS

The platform around a domain MCP server

CHANNELS + PERSONAS



The dividing line

STARTUP

**Control the model,
the route and the output.**

Tool loop · accuracy · UX · latency · cost

ENTERPRISE

**Control every identity, tool
and dataset,
then retain the evidence.**

Authorization · licensing · policy · audit · operations

MAKE IT WORK

MAKE IT REPEATABLE

MAKE IT GOVERNABLE

THANK YOU



Portfolio



LinkedIn



Continue the
conversation

kolygri.github.io